# 4.7 — Atelier 7 | Documenter les protections et leurs limites

**Objectif :** fournir les preuves techniques de sécurisation et justifier les protections compensatoires d'un équipement industriel obsolète.

**Modalité :** travail documentaire en autonomie ; formateur absent, ressources et entraide du groupe.

**Document unique :** `J4-configuration-tests-securite-IT-OT` **— Olivier HIMBLOT — 29 octobre 2026.**

Télécharger le dossier formateur en PDF

## Compétence C4 et portée du dossier

**Sécuriser les communications entre les environnements IT et OT.**

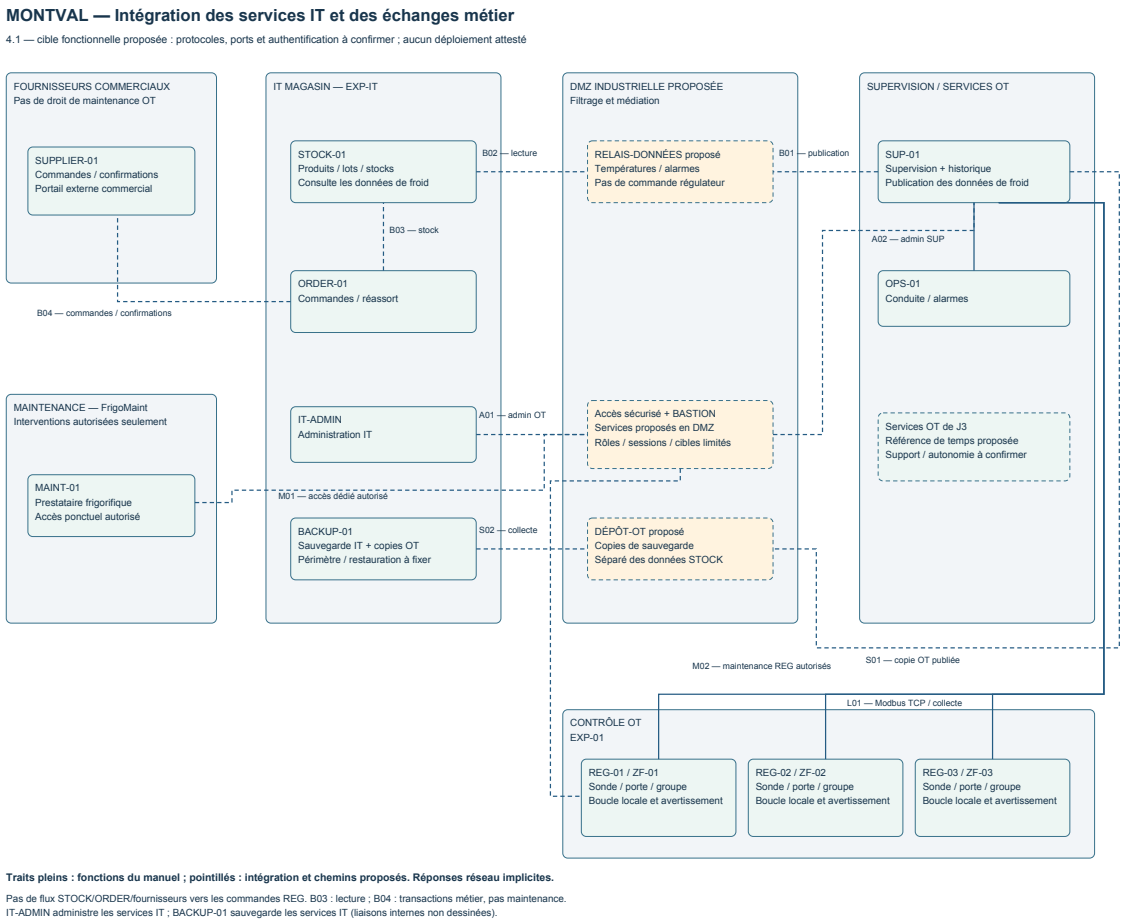
**Critères :** définit et applique des règles de filtrage ; vérifie les communications nécessaires ; justifie les protections compensatoires.

**Preuve de travail : J4 — Dossier de configuration et de tests de sécurité IT/OT.**

| Statut | Portée |
|---|---|
| Exigences et scénario | Manuel MAN-OT-01 et consignes J4 ; REG-02 sans support, sans correctif disponible et sans remplacement financé cette année. |
| Proposition Montval | Architecture d'entreprise, 32 règles symboliques, DMZ, bastion et GW-02 : conçus, pas déployés dans Montval. |
| Application et preuves | VM Debian 192.168.122.105 ; quatre espaces réseau, nftables, proxy Modbus, supervision, contrôles et captures réels du laboratoire. |
| Limites de validation | Simulation sans équipement réel ; pas de qualification d'une passerelle industrielle ni de validation exhaustive de l'architecture Montval. |

La consigne fournit la convention **[Nom]-[Prénom]-[Site]-Iteration2-Atelier7**. Elle est conservée ici ; le classement du mémo est **itération 3 / J4**. Le site n'étant pas renseigné, le nom du PDF utilise le titre du dossier et l'auteur, sans inventer cette donnée.

# 1 — Architecture de sécurité Montval proposée




L'architecture est une cible de conception. Les zones frigorifiques et leurs boucles de contrôle restent distinctes des fonctions de supervision, des services IT et des accès distants.

| Zone / composants | Fonction, échanges et frontières proposés |
|---|---|
| Processus et contrôle OT : ZF-01/02/03, sondes, groupes, REG-01/02/03 | Mesures et commandes locales ; maintien du contrôle local indépendamment du réseau IT. Liaisons physiques à confirmer sur site. |
| Supervision OT : SUP-01, OPS-01 | Collecte des mesures, états, alarmes et historiques ; consultation opérateur. Perte de supervision = perte de visibilité, pas arrêt systématique des régulateurs. |

| Zone / composants | Fonction, échanges et frontières proposés |
|---|---|
| Protection spécifique REG-02 : GW-02 et segment dédié | Source réseau aval unique vers REG-02 ; points d'entrée collecte, maintenance et administration séparés. Proposition non déployée. |
| DMZ : RELAIS-DONNÉES, DÉPÔT-OT, BASTION | Publication métier contrôlée, transfert des sauvegardes prévues et accès d'intervention ; aucun transit général vers les régulateurs. |
| IT magasin : STOCK-01, ORDER-01, IT-ADMIN, BACKUP-01 | STOCK consulte les données de conservation via le relais ; ORDER consulte STOCK et échange avec le portail fournisseur ; administration et sauvegarde bornées aux services utiles. |
| Extérieur : SUPPLIER-01 / FrigoMaint | Fournisseurs commerciaux : commandes métier seulement. FrigoMaint : accès autorisé par entrée contrôlée puis bastion, avec périmètre et durée limités. |

Les frontières IT/DMZ/OT doivent être traversées par des points de filtrage effectifs. Les flux de publication OT → relais et lecture STOCK → relais évitent un accès IT direct aux commandes. Les services de temps, sauvegarde et administration ne doivent pas devenir des chemins de contournement.

**Protocoles :** Modbus TCP/502 est retenu dans la consigne de conception. HTTPS/443 pour les services métier et opérateurs est une hypothèse conditionnelle. Les ports d'administration, de sauvegarde et de maintenance restent à qualifier ; une ligne conditionnelle n'est pas une autorisation déjà activée. Les ports **15020/15021/18080** appartiennent au PoC et ne décrivent pas Montval.

# 2 — Politique de pare-feu proposée pour Montval

La liste consolidée ci-dessous reprend les **32 règles proposées** en 4.2 et 4.3, avec leurs justifications et conditions. Elle n'est pas un fichier nftables appliqué à l'entreprise. Les interfaces, adresses réelles, protocoles inconnus et capacités des équipements sont à confirmer avant traduction technique.

Les refus de contournement et de droits retirés R00–R04/Q00–Q02 précèdent le traitement des connexions établies R05. Les autorisations métier et techniques sont suivies du refus par défaut ; les réponses restent limitées aux connexions permises. R10/R22 ne couvrent plus REG-02, remplacé par le chemin GW-02.

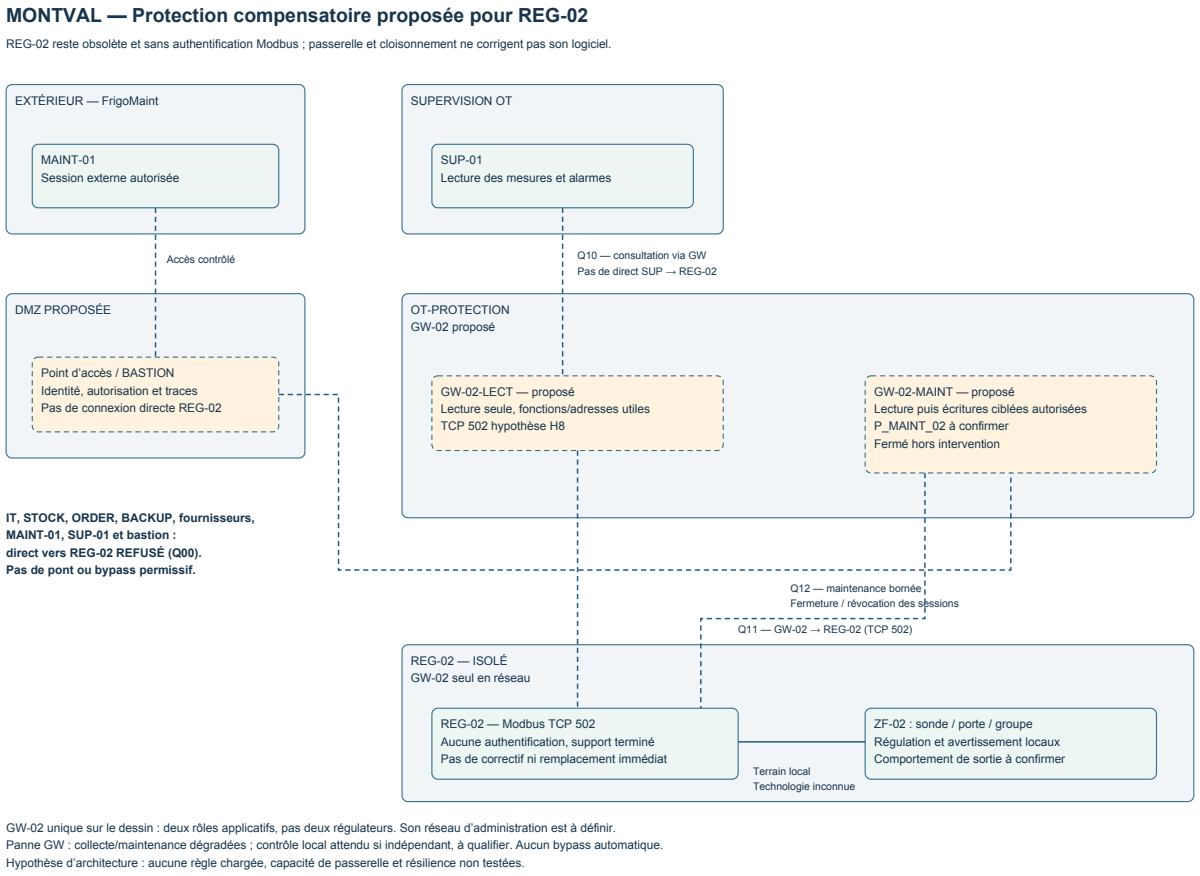
| Règle | Zone ou adresse source | Zone ou adresse destination | Protocole / port | Action | Justification | Conditions d'activation |
|---|---|---|---|---|---|---|
| R00 | Toutes zones traversantes | Toutes zones traversantes | Tous ; ct state invalid | REFUSER | Paquets invalides ; filtrage cohérent | Permanent ; politique proposée |
| R01 | IT dont IT-ADMIN, STOCK, ORDER, BACKUP ; extérieur dont MAINT direct | REG-01 à REG-03 / contrôle OT | Tous protocoles / ports | REFUSER | Pas de commande directe depuis IT ou extérieur | Tous états ; avant acceptation established |
| R02 | DMZ : RELAIS-DONNÉES, DÉPÔT-OT et autres sources sauf BASTION autorisé | REG-01 à REG-03 | Tous protocoles / ports | REFUSER | Empêcher le pivot par relais métier ou dépôt | Tous états ; BASTION soumis à R04 et R22 |
| R03 | Extérieur : fournisseurs et mainteneur | SUP-01 et OPS-01 | Tous protocoles / ports | REFUSER | Pas de publication directe de la supervision | Tous états ; accès de maintenance via DMZ seulement |
| R04 | Origines des flux temporaires A/M : IT-ADMIN, MAINT-01, accès distant, BASTION | Cibles de leurs règles temporaires | Tous protocoles / ports pour les tuples expirés ou révoqués | REFUSER | Une ancienne session ne doit pas prolonger une autorisation retirée | Contrôle de validité avant R05 ; par périmètre/source/cible, pas une coupure générale |
| Q00 | Toute source sauf interface aval autorisée de GW-02 | REG-02 | Tous protocoles / ports | REFUSER | REG-02 accessible uniquement par la passerelle contrôlée | Tous états ; avant established ; supprime le direct SUP et BASTION vers REG-02 |
| Q01 | Sources des accès temporaires à GW-02 | GW-02-MAINT et administration GW-02 | P_MAINT_02 / P_ADMIN_GW02 ; flux expirés ou révoqués | REFUSER | Ne pas laisser persister une session de maintenance retirée | Vérifier autorisation avant established ; fermer sessions et droits de façon ciblée |
| Q02 | Origines non autorisées pour chaque point d'entrée GW-02 | GW-02-LECT, GW-02-MAINT et administration | Tous protocoles / ports | REFUSER | Éviter le passage de SUP du rôle lecture vers le rôle écriture | GW-LECT : SUP-01 seul ; MAINT/admin : outil BASTION autorisé seulement, aux ports définis ; tous états |
| R05 | Extrémités d'un flux répertorié autorisé | Extrémité correspondante / réponse | Même connexion ; ct state established | AUTORISER | Poursuite et retour des seules sessions encore permises | Chemins/tuples encore autorisés ; refus R01–R04 et Q00–Q02 prioritaires ; Q01 pour révocation REG-02 |

| Règle | Zone ou adresse source | Zone ou adresse destination | Protocole / port | Action | Justification | Conditions d'activation |
|---|---|---|---|---|---|---|
| R06 | Équipements participant aux échanges permis | Extrémités concernées | ICMP/ICMPv6 nécessaires, ct state related ; types à préciser | AUTORISER SOUS CONDITION | Erreurs réseau et fonctionnement des communications permises | Périmètre qualifié ; pas de helper ouvrant implicitement des services applicatifs |
| R10 | OT-SUP : SUP-01 | OT-CTRL : REG-01 et REG-03 seulement | TCP / 502 (consigne 4.2) | AUTORISER | Collecte courante de températures, états et alarmes | REG-02 exclu : Q10/Q11 via GW-02 le remplacent ; lecture seule à garantir séparément pour REG-01/03 |
| Q10 | OT-SUP : SUP-01 | OT-PROTECTION : GW-02-LECT | TCP / 502 (H8 : écoute de passerelle proposée) | AUTORISER SOUS CONDITION | Consultation des données REG-02 par un endpoint sans écriture | Pas d'accès direct ; fonctions et plages de lecture utiles qualifiées ; aucune écriture via ce rôle |
| Q11 | Interface aval GW-02 | REG-02 | TCP / 502 (consigne 4.2, configuration à vérifier) | AUTORISER SOUS CONDITION | Transport des opérations validées par GW-02 | Seule source réseau admise ; la règle IP ne distingue pas lectures/écritures ; politique applicative indispensable |
| Q12 | Station ou outil autorisé via BASTION | GW-02-MAINT | P_MAINT_02 / protocole à confirmer (H9) | AUTORISER SOUS CONDITION | Diagnostic ou écritures spécifiquement accordées par intervention | Inactive sans protocole/outillage qualifiés ; cibles/fonctions/registres/valeurs et durée bornés ; traces puis révocation |
| Q13 | Station d'administration autorisée via BASTION | Administration de GW-02 | P_ADMIN_GW02 / protocole à confirmer (H10) | AUTORISER SOUS CONDITION | Administrer le dispositif de protection sans ouvrir son rôle industriel | Inactive sans protocole qualifié ; identité et changement autorisés ; sauvegarde de sa politique |
| Q90 | Sources ou services non couverts par Q10/Q12/Q13 | GW-02 | Tous protocoles / ports restants | REFUSER | Refus par défaut des autres services de passerelle | Après les seules autorisations valides ; journalisation limitée et compteur |
| R11 | OT-SUP : SUP-01 | DMZ : RELAIS-DONNÉES | TCP / 443 (H1) | AUTORISER SOUS CONDITION | Publication de données de conservation B01 | H1 validée ; compte de publication limité ; pas de commandes REG |
| R12 | IT : STOCK-01 | DMZ : RELAIS-DONNÉES | TCP / 443 (H1) | AUTORISER SOUS CONDITION | Lecture des seules données métier B02 | H1 validée ; rôle lecture ; pas d'accès aux sauvegardes ni au bastion |
| R13 | IT : ORDER-01 | IT : STOCK-01 | TCP / 443 (H1) | AUTORISER SOUS CONDITION | Consultation des stocks B03 | H1 validée ; si même réseau, filtrage hôte ou séparation rendant le flux contrôlable |
| R14 | IT : ORDER-01 | Externe commercial : SUPPLIER-01 | TCP / 443 (H1) | AUTORISER SOUS CONDITION | Commandes et confirmations B04 | H1 validée ; destinations du portail délimitées ; réponses R05, pas nouvelle session entrante générale |
| R15 | OT-SUP : OPS-01 | OT-SUP : SUP-01 | TCP / 443 (H2) | AUTORISER SOUS CONDITION | Vue opérateur et acquittements autorisés | H2 validée ; droits applicatifs distincts des écritures de consigne |
| R16 | IT : IT-ADMIN | IT : STOCK-01, ORDER-01, BACKUP-01 selon rôle | P_ADMIN_IT / protocole à confirmer (H3) | AUTORISER SOUS CONDITION | Administration IT | Inactive tant que protocole inconnu ; activation sur changement autorisé ; pas extension aux REG |

| Règle | Zone ou adresse source | Zone ou adresse destination | Protocole / port | Action | Justification | Conditions d'activation |
|---|---|---|---|---|---|---|
| R17 | IT : BACKUP-01 | IT : sources STOCK-01, ORDER-01 prévues | P_BACKUP_IT / protocole à confirmer (H4) | AUTORISER SOUS CONDITION | Collecte des sauvegardes IT S00 | Mode tiré à valider ; compte de sauvegarde limité ; fenêtre et charge maîtrisées |
| R18 | OT-SUP : SUP-01 | DMZ : DÉPÔT-OT | TCP / 443 (H5) | AUTORISER SOUS CONDITION | Publication de copies OT S01 | H5 validée ; mode poussé ; compte dédié ; pas d'alias commun avec relais métier |
| R19 | IT : BACKUP-01 | DMZ : DÉPÔT-OT | TCP / 443 (H5) | AUTORISER SOUS CONDITION | Récupération des copies OT S02 | H5 validée ; lecture du dépôt ; ne donne aucun accès BACKUP vers les REG |
| R20 | Externe maintenance : MAINT-01 via point d'accès défini | DMZ : service d'entrée distant | TCP / 443 (H6) | AUTORISER SOUS CONDITION | Entrée FrigoMaint M01 | H6 et provenance validées ; identité, intervention autorisée, expiration et traces |
| R21 | Session distante relayée ; IT-ADMIN autorisé | DMZ : service BASTION | P_SESSION / protocole à confirmer (H6) | AUTORISER SOUS CONDITION | Ouverture de session vers les cibles accordées | Pas d'autorisation tant que protocole indéfini ; si entrée et bastion même service, pas de flux réseau inventé |
| R22 | DMZ : station ou outil de maintenance du BASTION | OT-CTRL : REG-01 et REG-03 concernés seulement | TCP / 502 pour diagnostic Modbus ; autres ports non ouverts | AUTORISER SOUS CONDITION | Diagnostic et opérations Modbus autorisées M02 | REG-02 exclu : Q12 puis Q11 ; intervention autorisée pour REG-01/03, contrôles applicatifs requis |
| R23 | DMZ : station d'administration du BASTION | OT-SUP : SUP-01 | P_ADMIN_SUP / protocole à confirmer (H3) | AUTORISER SOUS CONDITION | Administration de la supervision A02 | Inactive tant que protocole inconnu ; changement autorisé ; aucune modification implicite des consignes |
| R24 | OT : SUP-01, OPS-01 si compatibles | OT-SERV : S-TEMPS proposé | UDP / 123 (H7) | AUTORISER SOUS CONDITION | Cohérence temporelle EXP-06 | H7 validée ; clients nommés et référence unique prévue ; pas de service entrant depuis Internet |
| R90 | Hôtes et zones non couverts par une autorisation valide | Autres zones / services non autorisés | Tous protocoles / ports restants | REFUSER | Refus explicite et observation des écarts | Journalisation limitée en débit ; compteur ; le refus continue même si les logs sont limités |
| R99 | Toutes origines sur les frontières couvertes | Toutes destinations non acceptées | Tous protocoles / ports restants | REFUSER PAR DÉFAUT | Aucune ouverture implicite | Policy drop des chaînes de filtrage concernées ; couverture IPv4/IPv6 et autres chemins vérifiée |

CSV de la politique proposée. Un filtrage IP/port ne sépare généralement pas FC03 et FC06 dans la même connexion Modbus : le contrôle applicatif reste nécessaire lorsque seule la lecture est permise.

# 3 — Protection compensatoire de REG-02




| Mesure retenue dans la proposition | Protection recherchée | Limite et condition |
|---|---|---|
| Segment REG-02 dédié et filtrage obligatoire | Aucun accès direct depuis IT, SUP ou bastion ; seule l'interface aval GW-02 communique avec REG-02. | Un chemin latéral, local ou physique peut contourner le routeur ; contrôler câblage, ponts, IPv6 et pairs du segment. |
| GW-02-LECT pour SUP-01 | Lectures utiles seulement, fonctions et plages qualifiées. | Plages industrielles non fournies ; les lectures peuvent elles-mêmes exposer des défauts du régulateur. |

| Mesure retenue dans la proposition | Protection recherchée | Limite et condition |
|---|---|---|
| GW-02-MAINT séparé, fermé hors intervention | Écritures limitées aux fonctions, registres, valeurs et cibles autorisés. | Protocole et outillage à confirmer ; une IP ou un port ne représente pas une identité humaine. |
| FrigoMaint via accès contrôlé et bastion | Identité, durée, justification, traces puis révocation de la session. | Bastion et passerelle peuvent être compromis ; aucun déploiement ni test de MFA/session industrielle attesté ici. |
| Surveillance, sauvegarde si supportée et retour arrière | Détecter les changements et préparer une reprise maîtrisée. | Fonction de sauvegarde du REG inconnue ; pas de restauration réelle démontrée. |
| Remplacement préparé à moyen terme | Retour à un équipement maintenu et qualifié. | Aucun financement cette année ; les mesures ne corrigent pas le logiciel obsolète. |

GW-02 ne doit pas être inséré dans la boucle sonde/commande locale. Sa panne peut interrompre visibilité et maintenance ; le contrôle local doit être vérifié dans les conditions réelles. Ne pas prévoir de bypass permissif automatique. Le maintien obligatoire ne démontre pas l'acceptabilité du risque résiduel.

Le proxy Python testé autorise FC01–FC04 et refuse les autres fonctions. Il ne fournit ni authentification humaine, ni contrôle fin des plages/valeurs, ni endpoint d'écriture de maintenance, ni qualification industrielle. Les essais du PoC illustrent seulement une partie de la proposition GW-02.

# 4 — Configuration réellement appliquée dans le laboratoire

| Espace | Adresse et rôle |
|---|---|
| ais45-it | it0 : 10.77.10.2/24, route par 10.77.10.1 ; client IT. |
| ais45-fw | fw-it : 10.77.10.1 ; fw-dmz : 10.77.20.1 ; fw-ot : 10.77.30.1 ; routage IPv4 et filtrage. |
| ais45-gw | dmz0 : 10.77.20.2/24 ; passerelle TCP15021 et dashboard HTTP18080. |
| ais45-ot | ot0 : 10.77.30.2/24 ; serveur Modbus TCP15020, modèle thermique et contrôle. |

```
Client IT -- fw-it [ais45-fw] fw-dmz -- GW (15021 + 18080)
                        |
                      fw-ot -- OT (15020)
IT -> OT direct : refus ; GW -> OT : autorisé
Dashboard -> passerelle -> serveur : collecte Modbus
```

La table **inet ais45**, chaîne **forward**, est appliquée **uniquement dans ais45-fw**, sur le chemin routé du trafic. La politique est DROP. Les refus directs IT/OT sont évalués avant les autorisations de connexion. Seuls IT → GW15021/18080 et GW → OT15020, leurs retours établis et les erreurs ICMP liées prévues sont permis. Les autres flux interzones sont refusés et comptés.

La topologie ne dispose pas de lien vers le LAN de gestion, ni NAT Internet ; IPv6 y est désactivé. L'accès SSH de gestion de la VM ne traverse pas ces namespaces. Le serveur direct reste joignable depuis GW : la séparation des processus dans un même hôte GW n'est donc pas une séparation industrielle complète.

## Export réel initial, conservé sans réécriture des compteurs

```
table inet ais45 { # handle 4
    counter it_direct_drop { # handle 2
        packets 3 bytes 180
    }

    counter it_gateway_accept { # handle 3
        packets 54 bytes 3099
    }

    counter gateway_ot_accept { # handle 4
        packets 72 bytes 3984
    }

    counter replies_accept { # handle 5
        packets 86 bytes 5138
    }

    counter other_drop { # handle 6
        packets 0 bytes 0
    }

    chain forward { # handle 1
        type filter hook forward priority filter; policy drop;
        ct state invalid counter packets 0 bytes 0 drop comment "Paquets invalides" # handle 7
        meta nfproto ipv6 counter name "other_drop" drop comment "TP IPv4 seulement" # handle 8
        iifname "fw-it" oifname "fw-ot" counter name "it_direct_drop" drop comment "Direct IT vers OT interdit, tous états" # handle 9
        iifname "fw-ot" oifname "fw-it" counter name "it_direct_drop" drop comment "Aucun retour direct OT vers IT" # handle 10
        iifname "fw-it" oifname "fw-dmz" ip saddr 10.77.10.2 ip daddr 10.77.20.2 tcp dport { 15021, 18080 } ct state { established, new } counter name
    "it_gateway_accept" accept comment "Consultation Modbus via GW et HTTP du TP" # handle 13
        iifname "fw-dmz" oifname "fw-it" ip saddr 10.77.20.2 ip daddr 10.77.10.2 tcp sport { 15021, 18080 } ct state established counter name "replies_accept"
    accept comment "Réponses GW vers IT seulement" # handle 15
        iifname "fw-dmz" oifname "fw-ot" ip saddr 10.77.20.2 ip daddr 10.77.30.2 tcp dport 15020 ct state { established, new } counter name "gateway_ot_accept"
    accept comment "Passerelle seule vers serveur OT" # handle 17
        iifname "fw-ot" oifname "fw-dmz" ip saddr 10.77.30.2 ip daddr 10.77.20.2 tcp sport 15020 ct state established counter name "replies_accept" accept
    comment "Réponses serveur vers GW" # handle 18
        ct state related icmp type { destination-unreachable, time-exceeded, parameter-problem } counter packets 0 bytes 0 accept comment "Erreurs liées aux
    connexions suivies" # handle 20
        counter name "other_drop" drop comment "Autres communications interzones refusées" # handle 21
    }
}
```

Les compteurs de cet export sont ceux du run initial, pas les valeurs de tous les essais ultérieurs. Exporter les règles réelles ; source reproductible ; archive du laboratoire et scripts.

# 5 — Résultats de tests et observations

Les résultats ont été établis dans le laboratoire le **29 octobre 2026**. Le run initial de 10:47:41 et sa copie sont conservés ; une nouvelle vérification datée de **11:36:51** a actualisé le fichier sur la VM, dont une copie distincte est archivée. Les preuves des deux instants ne sont pas fusionnées.

| Test / attente | Résultat observé | Preuve et limite |
|---|---|---|
| IT → OT direct : refus | Timeout ; serveur joignable par GW ; compteur de refus 18 → 21 sur essai manuel, puis 21 → 24 au nouveau run. | Captures et JSON ; trois paquets ne sont pas trois utilisateurs. |
| GW → OT : autorisé | Lectures status réussies avant et après coupure. | CLI, JSON et compteurs du chemin autorisé. |
| IT → GW : consultation autorisée | Lectures FC03/FC04/FC01, données retournées. | PCAP de 39 trames : 10/12, 20/22, 30/32. |
| Écriture via GW : rejet | FC06 et FC05 : exception Modbus 01 ; consigne et porte conservées. | JSON de vérification ; FC06 également visible en CLI. Le PCAP fourni ne contient aucune écriture. |
| Supervision : collecte maintenue hors coupure | HTTP 200 sur /api, consigne et mesures cohérentes avec les lectures. | API attestée, pas preuve d'une session graphique supplémentaire. |
| Service non autorisé 18081 : refus par défaut | HTTP 200 depuis GW ; timeout depuis IT ; other_drop 0 → 3 paquets / 180 octets. | Captures complémentaires 4.5 ; pas de nouvelle source testée. |
| Contrôle local pendant coupure de fw-dmz | À 11:37–11:38 : 3,6 → 4,5 → 4,1 °C ; compresseur 0 → 1, consigne 4 °C, porte/défaut/alarme à 0, auto 1. | Relevés depuis ais45-ot ; cycle complet et tentative IT/HTTP pendant coupure non capturés. |
| Retour après restauration explicite | À 11:41:45 : fw-dmz UP/LOWER_UP, deux lectures réussies, HTTP 200 ; température 4,1 °C, consigne 4 °C, compresseur 0. | Capture de reprise ; délai exact et exécution finale du trap non mesurés. |

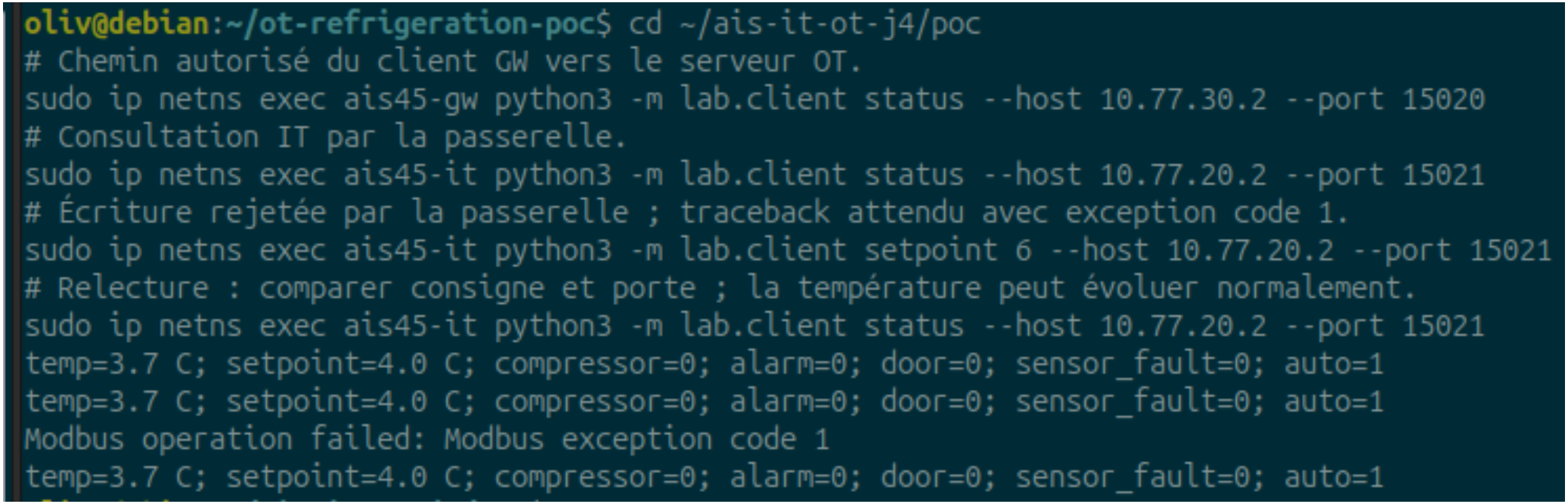
La température varie entre les relevés et la commande peut conserver son état dans la bande d'hystérésis. La transition observée pendant coupure étaye le maintien du contrôle local simulé ; elle ne qualifie pas la disponibilité d'une installation physique.

## Écart rencontré et diagnostic

La nouvelle exécution affiche « Ruleset hôte différent ». La comparaison en lecture seule des exports avant/après montre une seule différence : **compteur NAT PREROUTING Docker de 6 paquets / 360 octets à 12 paquets / 720 octets**. Aucune différence de règle, politique ou handle n'apparaît. Le script compare les compteurs avec le reste du texte : cet écart ne démontre pas une modification de politique. L'origine des paquets supplémentaires n'est pas établie. Aucune correction des règles n'a été nécessaire pour les tests documentés.

# Annexe A — Preuves visuelles représentatives

### Lectures et refus FC06, 11:35:52



### Refus direct et compteur 18 → 21, 11:36:19

```
oliv@debian:~/ais-it-ot-j4/poc$ sudo ip netns exec ais45-fw nft list counter inet ais45 it_direct_drop
sudo ip netns exec ais45-it python3 -m lab.client status --host 10.77.30.2 --port 15020
sudo ip netns exec ais45-fw nft list counter inet ais45 it_direct_drop
table inet ais45 {
        counter it_direct_drop {
                packets 18 bytes 1080
        }
}
Traceback (most recent call last):
  File "<frozen runpy>", line 198, in _run_module_as_main
  File "<frozen runpy>", line 88, in _run_code
  File "/home/oliv/ais-it-ot-j4/poc/lab/client.py", line 25, in <module>
    main()
    ~~~~^^
  File "/home/oliv/ais-it-ot-j4/poc/lab/client.py", line 13, in main
    hr=c.request(3,0,3); ir=c.request(4,0,4); coils=c.request(1,0,2)
  File "/home/oliv/ais-it-ot-j4/poc/lab/modbus.py", line 84, in request
    with socket.create_connection((self.host,self.port),self.timeout) as s:
         ~~~~~~~~~~~~~~~~~~~~~~~~^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
  File "/usr/lib/python3.13/socket.py", line 864, in create_connection
    raise exceptions[0]
  File "/usr/lib/python3.13/socket.py", line 849, in create_connection
    sock.connect(sa)
    ~~~~~~~~~~~~~^^^^
TimeoutError: timed out
table inet ais45 {
        counter it_direct_drop {
                packets 21 bytes 1260
        }
}
```

### Coupure : contrôle local, 11:37–11:38

```
oliv@debian:~/ais-it-ot-j4/poc$ sudo bash <<'SH'
set -eu
cd /home/oliv/ais-it-ot-j4/poc
restore_link() { ip -n ais45-fw link set fw-dmz up; }
trap restore_link EXIT
trap 'exit 130' INT
trap 'exit 143' TERM
ip -n ais45-fw link set fw-dmz down
for n in $(seq 1 19); do
    date -Is
    ip netns exec ais45-ot python3 -m lab.client status --host 10.77.30.2 --port 15020
    if [ "$n" -lt 19 ]; then sleep 10; fi
done
SH
2026-10-29T11:37:08+01:00
temp=3.6 C; setpoint=4.0 C; compressor=0; alarm=0; door=0; sensor_fault=0; auto=1
2026-10-29T11:37:18+01:00
temp=3.7 C; setpoint=4.0 C; compressor=0; alarm=0; door=0; sensor_fault=0; auto=1
2026-10-29T11:37:28+01:00
temp=3.8 C; setpoint=4.0 C; compressor=0; alarm=0; door=0; sensor_fault=0; auto=1
```

```
oliv@debian:~/ais-it-ot-j4/poc$ sudo bash <<'SH'
set -eu
cd /home/oliv/ais-it-ot-j4/poc
restore_link() { ip -n ais45-fw link set fw-dmz up; }
trap restore_link EXIT
trap 'exit 130' INT
trap 'exit 143' TERM
ip -n ais45-fw link set fw-dmz down
for n in $(seq 1 19); do
    date -Is
    ip netns exec ais45-ot python3 -m lab.client status --host 10.77.30.2 --port 15020
    if [ "$n" -lt 19 ]; then sleep 10; fi
done
SH
2026-10-29T11:38:19+01:00
temp=4.5 C; setpoint=4.0 C; compressor=0; alarm=0; door=0; sensor_fault=0; auto=1
2026-10-29T11:38:29+01:00
temp=4.3 C; setpoint=4.0 C; compressor=1; alarm=0; door=0; sensor_fault=0; auto=1
2026-10-29T11:38:39+01:00
temp=4.0 C; setpoint=4.0 C; compressor=1; alarm=0; door=0; sensor_fault=0; auto=1
```

## Reprise des lectures et HTTP 200, 11:41:45

```
oliv@debian:~/ais-it-ot-j4/poc$ cd ~/ais-it-ot-j4/poc

# Rétablir le lien et afficher son état.
sudo ip -n ais45-fw link set fw-dmz up
date -Is
sudo ip -n ais45-fw -br link show fw-dmz

# Vérifier les deux chemins de lecture.
sudo ip netns exec ais45-gw python3 -m lab.client status --host 10.77.30.2 --port 15020
sudo ip netns exec ais45-it python3 -m lab.client status --host 10.77.20.2 --port 15021

# Vérifier la reprise de la collecte de supervision.
sudo ip netns exec ais45-it python3 - <<'PY'
import urllib.request
with urllib.request.urlopen("http://10.77.20.2:18080/api", timeout=4) as r:
    print("HTTP", r.status)
    print(r.read().decode())
PY
2026-10-29T11:41:45+01:00
fw-dmz@if2       UP             ba:7f:05:ca:f6:91 <BROADCAST,MULTICAST,UP,LOWER_UP>
temp=4.1 C; setpoint=4.0 C; compressor=0; alarm=0; door=0; sensor_fault=0; auto=1
temp=4.1 C; setpoint=4.0 C; compressor=0; alarm=0; door=0; sensor_fault=0; auto=1
HTTP 200
{"temperature": 4.1, "setpoint": 4.0, "compressor": false, "alarm": false, "door": false}
oliv@debian:~/ais-it-ot-j4/poc$
```

Les autres captures et le test 18081 sont commentés dans les fiches 4.5 et 4.6 ; les cinq images ci-dessus sont incluses dans le même PDF. Elles sont des observations de laboratoire, pas des captures de l'installation Montval réelle.

# 6 — Limites, améliorations et conservation pour J5

| Protection ou amélioration | État et action restante |
|---|---|
| Filtrage réseau et refus par défaut | Déployés dans le TP ; pas d'application des 32 règles à une infrastructure Montval. |
| Passerelle lecture seule | FC05/FC06 refusées dans le TP ; qualifier parsing, erreurs, plages, cadences et risques des fonctions autorisées avant usage industriel. |
| DMZ, bastion, accès distant temporaire | Proposés ; identités, MFA, révocation, journalisation et chemin industriel non déployés. |
| Journaux des connexions refusées | Compteurs et captures testés ; pas de journalisation nft dédiée ni de centralisation des refus attestée. Prévoir débit limité et conservation. |
| Détection Modbus inhabituelle / Suricata | Analyse Wireshark réalisée ; aucune règle Suricata ni alerte automatique testée dans ce TP. |
| Panne/reprise du processus passerelle | Non testée : l'essai a coupé un lien, sans arrêter GW. Préparer un scénario distinct. |
| Session persistante, nouvelle source, protocoles alternatifs | Révocation persistante et nouvelle source non testées ; IPv6 désactivé dans le TP, pas qualifié en double pile. |
| Sauvegarde, restauration et remplacement de REG-02 | Capacités réelles à confirmer, recette et financement à préparer ; logiciel obsolète non corrigé par le filtrage. |

**Conservation J5 :** garder le PoC, les scripts, la source nft, les exports réels datés, les deux JSON, les captures et le PCAP. Ne pas lancer `teardown` ni `reset-filter` avant l'investigation. L'état final capturé montre le lien UP, les lectures et l'API disponibles, consigne 4 °C, porte fermée, défaut absent et mode automatique actif. L'arrêt du serveur HTTP temporaire 18081 n'est pas attesté ; vérifier son état et conserver cette information avant tout changement.

**Vérification documentaire :** besoins et règles tracés ; REG-02 limité dans la proposition ; fichier appliqué et emplacement explicités ; résultats positifs/négatifs et reprise observés ; protections non déployées et limites indiquées. Le dossier fournit des preuves pour C4 ; la décision de validation appartient au formateur.

## Références et fichiers de preuve

- Manuel MAN-OT-01 et consignes des ateliers 4.1 à 4.7.
- 4.1 — Architecture et services, 4.2 — Politique proposée, 4.3 — REG-02.
- 4.5 — Déploiement, captures et preuves, 4.6 — Tests, coupure et reprise.
- JSON initial et JSON de 11:36:51.
- PCAP original, SHA-256 : `2138953a3cf6c0fea0ed4094ec9f38e6c858a7388af82e750bd3aea5de005f5f`.
- Schéma Montval modifiable et schéma REG-02 modifiable.

Retour à l'itération 3 · Pense-bête